SICHERHEITSBEFUND · E-MAIL, DOMAIN UND WEBSITE

reineke-technik.de

Unabhängige Prüfung der von außen sichtbaren Sicherheit von reineke-technik.de. Automatisierte Analyse mit scan.reineke.tech.

Sicherheitslücken schließen, bevor sie teuer werden.

ERSTELLT VON

Reineke Technik GmbH
Geseker Straße 26 · 33154 Salzkotten
www.reineke-technik.de

PRÜFDATUM

30. Oktober 2026
Bericht-Nr. RT-DS-00000000-0000

VERTRAULICH

Nur für den internen Gebrauch der Adressaten bestimmt.

Inhalt

Für die Geschäftsführung: Kapitel 01 bis 04. Für Ihre IT: Kapitel 05 und der Anhang.

01 **Zusammenfassung** 3

02 **Empfehlungen** 4

Über diesen Befund hinaus: Penetrationstest 4

03 **Über Reineke Technik** 5

04 **Nächster Schritt** 6

Ergebnisbesprechung: Termin direkt aus dem Bericht buchen 6

05 **Feststellungen im Einzelnen** 7

- F-01 Gefälschte E-Mails sollen nur aussortiert werden 7
- F-02 Liste berechtigter Mailserver verbesserbar 7
- F-03 Verschlüsselte Zustellung nicht verbindlich 7
- F-04 Keine Fehlerberichte zur Verschlüsselung 7
- F-05 Fremde Skripte ohne Prüfung auf Veränderungen 7

Bereits umgesetzt 8

A **Messwerte** 9

B **Methodik und Bewertung** 11

01

Zusammenfassung

GESAMTURTEIL

Ausgewertet wurden ausschließlich öffentlich abrufbare Informationen. Es gab keinen Eingriff in Ihre Systeme, keine Anmeldung und keine nennenswerte Last.

Handlungsbedarf

Gering

Das heißt:
Einzelne Punkte bei Gelegenheit verbessern.

GERING | MITTEL | HOCH | KRITISCH

Die geprüften Schutzmechanismen sind weitgehend umgesetzt. Ob Ihre Systeme auch einem gezielten Angriff standhalten, klärt ein Penetrationstest.

E-MAIL · DMARC
Schutz vor gefälschten Absendern

A+

Sehr gut

A | B | C | D | F

Gefälschte E-Mails mit Ihrem Absender sollen nur aussortiert werden.

Score 100 · Geprüfter Schutz umgesetzt

DOMAIN · DNSSEC
Echtheit der Adressauskünfte

A+

Sehr gut

A | B | C | D | F

Die Adressauskünfte Ihrer Domain sind digital signiert.

Score 100 · Geprüfter Schutz umgesetzt

WEBSITE · HTTP OBSERVATORY
Schutz Ihrer Website-Besucher

A+

Sehr gut

A | B | C | D | F

11 von 12 Tests bestanden. Die Note gewichtet nach Schwere.

Score 125 · Geprüfter Schutz umgesetzt

NOTENSKALA — **A+ bis A−** sehr gut · **B+ bis B−** gut · **C+ bis C−** verbesserungswürdig · **D+ bis D−** mangelhaft · **F** ungenügend

NÄCHSTER SCHRITT

Ergebnisbesprechung

In 20 Minuten legen wir gemeinsam fest, was zuerst angegangen wird, gern mit Ihrer IT. Kostenfrei und unverbindlich.

Termin wählen

02

Empfehlungen

Details zu den Feststellungen: Kapitel 05 ab Seite 7.

NR.	DRINGLICHKEIT	MASSNAHME	AUFWAND BEZUG
M-1	GERING	**E-Mail-Absender absichern** DMARC-Richtlinie auf „reject“ anheben; SPF-Eintrag prüfen und bereinigen.	Gering F-01, F-02 · S. 7
M-2	GERING	**Website-Schutzregeln ergänzen und verschärfen** Betroffen: Subresource Integrity.	Gering F-05 · S. 7
M-3	GERING	**Verschlüsselte E-Mail-Zustellung absichern** MTA-STS einrichten, damit E-Mails an Sie nur verschlüsselt zugestellt werden dürfen; TLS-RPT einrichten, damit Probleme bei der verschlüsselten Zustellung gemeldet werden.	Gering bis mittel F-03, F-04 · S. 7
M-4	Abschluss	**Umsetzung überprüfen** Nach der Umsetzung prüfen wir kostenfrei erneut. Der neue Befund zeigt, was behoben ist.	Kostenfrei Alle

PENETRATIONSTEST

Extern
Aus dem Internet erreichbare Systeme und Dienste

Intern / Active Directory
Firmennetz, Berechtigungen, Rechteausweitung

Webanwendung
Portale, Shops und Kundenzugänge

Über diesen Befund hinaus: Penetrationstest

Dieser Befund zeigt einen Ausschnitt dessen, was von außen sichtbar ist. Ein Penetrationstest klärt, was ein Angreifer erreicht, wenn er Schwachstellen zu einem Angriffspfad verkettet. Sie erhalten priorisierte Maßnahmen und einen Nachweis für Kunden und Prüfer.

1 **Vorbereitung**
Ziele, Systeme und Prüftiefe festlegen, Zeitfenster betriebsschonend abstimmen.

2 **Test**
Manuell und mit eigenen Werkzeugen, jeder Schritt nachvollziehbar dokumentiert.

3 **Bericht und Besprechung**
Priorisierte Feststellungen mit konkreten Behebungsempfehlungen.

4 **Nachtest**
Nach Ihrer Nachbesserung prüfen wir die Wirksamkeit erneut.

Umfang und Anfrage: scan.reineke.tech/pentest

03

Über Reineke Technik



Werner Francis Reineke

Geschäftsführer, Reineke Technik GmbH

Reineke Technik prüft die IT-Sicherheit mittelständischer Industrie- und Produktionsunternehmen und unterstützt bei Anforderungen wie NIS-2, ISO 27001 und TISAX.

Wir haben Netzwerke selbst aufgebaut und betrieben. Diese Praxis fließt in jede Prüfung ein: Wir wissen, wo Angreifer ansetzen und wo im Betriebsalltag Lücken entstehen.

„Sicherheitslücken schließen, bevor sie teuer werden."

Unabhängig

Wir prüfen Systeme, die wir nicht selbst betreiben, und verkaufen keine Technik, die wir anschließend kontrollieren.

Verständlich

Jeder Bericht enthält eine Zusammenfassung für die Geschäftsführung und einen priorisierten Maßnahmenplan.

Nachweisbar

Nach der Behebung prüfen wir erneut. So wird Sicherheit gegenüber Kunden und Prüfern belegbar.

KUNDEN

47

Unternehmen seit Gründung, überwiegend Industrie und Zulieferer

FACHVORTRÄGE

Live-Hacking

Referent, u. a. in der Cybersecurity-Vortragsreihe von SHARP

STANDORT

Salzkotten

Ostwestfalen-Lippe, vor Ort in NRW

LEISTUNGEN

- Penetrationstests: extern, intern, Webanwendungen
- ISMS-Aufbau nach ISO 27001
- Externes Sicherheitsmandat (eISB / vCISO)
- NIS-2-Bestandsaufnahme der Sicherheitsmaßnahmen
- TISAX-Begleitung für Zulieferer

04

Nächster Schritt

ERGEBNISBESPRECHUNG
reineke-technik.de

In 20 Minuten legen wir gemeinsam fest, was zuerst angegangen wird, gern mit Ihrer IT. Kostenfrei und unverbindlich.

Termin per QR-Code

Termin wählen

SCHRITT
1
Ergebnisbesprechung
Feststellungen einordnen, Prioritäten festlegen.

SCHRITT
2
Umsetzung
Ihre IT oder Ihr IT-Dienstleister, auf Wunsch mit unserer fachlichen Begleitung.

SCHRITT
3
Kontrolle
Wiederholungsprüfung, auf Wunsch Penetrationstest.

ANSPRECHPARTNER



Werner Francis Reineke
Geschäftsführer
wf.reineke@reineke-technik.de
+49 172 2872390

Karl Pieper
Geschäftsführer
k.pieper@reineke-technik.de
+49 5259 9870
+49 172 5209052 (mobil)

REINEKE

ANSCHRIFT
Reineke Technik GmbH
Geseker Straße 26
33154 Salzkotten
www.reineke-technik.de

PENETRATIONSTEST ANFRAGEN
scan.reineke.tech/pentest

Amtsgericht Paderborn · HRB 15938 · Geschäftsführer: Werner Francis Reineke, Karl Pieper · USt-IdNr. DE353762579

05 Feststellungen im Einzelnen

Weitere Feststellungen

GERING

F-01
E-Mail · DMARC

Gefälschte E-Mails sollen nur aussortiert werden
Gefälschte E-Mails landen im Spam-Ordner, statt abgewiesen zu werden.
Aufwand gering: Richtlinie auf „reject“ anheben.

F-02
E-Mail · SPF

Liste berechtigter Mailserver verbesserbar
Der SPF-Eintrag lässt sich verbessern.
Aufwand gering: Eintrag prüfen und bereinigen.

F-03
E-Mail · MTA-STS

Verschlüsselte Zustellung nicht verbindlich
E-Mails an Sie können auf dem Transportweg unverschlüsselt übertragen werden.
Aufwand gering bis mittel: Richtliniendatei mit gültigem Zertifikat und DNS-Eintrag anlegen.

F-04
E-Mail · TLS-RPT

Keine Fehlerberichte zur Verschlüsselung
Sie erfahren nicht, wenn verschlüsselte Zustellung scheitert.
Aufwand gering: Ein DNS-Eintrag.

F-05
Website · Subresource Integrity

Fremde Skripte ohne Prüfung auf Veränderungen
Fremder Programmcode wird geladen, ohne zu prüfen, ob er verändert wurde.
Aufwand gering: Prüfsummen für externe Skripte ergänzen.

Technische Einzelwerte zu allen Feststellungen in Anhang A, Maßnahmen in Kapitel 02.

BEREITS UMGESETZT

8

Punkte

Ihr DMARC-Eintrag weist Mailserver an, E-Mails mit gefälschtem Absender abzuweisen oder auszusortieren: ein wesentlicher Baustein gegen Rechnungs- und Chef-Betrug.

- Gefälschte E-Mails sollen aussortiert werden (DMARC „quarantine“)
- Auswertungsberichte angefordert (DMARC)
- Signaturschlüssel veröffentlicht (1 DKIM-Selektor gefunden)
- Adressauskünfte digital signiert (DNSSEC)
- Seitenadressen werden nicht an fremde Seiten weitergegeben (Referrer-Policy)
- Einbettung in fremde Seiten ist unterbunden (frame-ancestors)
- Geöffnete Fenster sind gegen fremden Zugriff abgeschirmt (Cross-Origin-Opener-Policy)
- Fremde Seiten können einzelne Inhalte der Website nicht abrufen (Cross-Origin-Resource-Policy)

A Messwerte

PRÜFUNG	ERGEBNIS	MESSWERT
E-MAIL		
DMARC	A+ Score 100	`v=DMARC1; p=quarantine; adkim=r; aspf=r; rua=mailto:3e33bb94907441109978b4d08903f247@dmarc-reports.cloudflare.net` Richtlinie (p): quarantine · Berichte (rua): angefordert
SPF	HINWEIS	SPF vorhanden, Verbesserungen möglich.
DKIM	OK	1 DKIM-Selektor gefunden
MX (Mailserver)	HINWEIS	1 MX-Server gefunden
MTA-STS	HINWEIS	Kein MTA-STS
TLS-RPT	HINWEIS	Kein TLS-RPT
DOMAIN		
DNSSEC	A+ Score 100	Zone signiert

ANHANG A

Messwerte, Fortsetzung

PRÜFUNG	ERGEBNIS	MESSWERT
WEBSITE		
HTTP Observatory	**A+** Score 125	11 von 12 Tests bestanden. Einzelergebnisse:
Subresource Integrity (SRI)	**−5**	Subresource Integrity (SRI) nicht implementiert, aber alle externen Skripte werden über HTTPS geladen. Empfehlung: SRI für externe Skripte ergänzen.
Content Security Policy (CSP)	**0**	Content Security Policy (CSP) mit unsicheren Quellen in style-src ('unsafe-inline', data: o. Ä.). Empfehlung: style-src absichern: 'unsafe-inline', data: und breite Quellen entfernen.
Cookies	**0**	Keine Cookies erkannt. Empfehlung:
Cross-Origin-Embedder-Policy	**0**	Cross-Origin-Embedder-Policy header not implemented. Empfehlung: Set to require-corp or credentialless.
CORS	**0**	Inhalte sind nicht per Cross-Origin Resource Sharing (CORS) sichtbar. Empfehlung:
Weiterleitung auf HTTPS	**0**	Erste Weiterleitung geht per HTTPS auf denselben Host, Endziel ist HTTPS. Empfehlung:
HSTS (Strict-Transport-Security)	**0**	Strict-Transport-Security auf mindestens sechs Monate (15768000 s) gesetzt. Empfehlung: Preloading erwägen: preload und includeSubDomains ergänzen, max-age auf mind. 1 Jahr erhöhen.
X-Content-Type-Options	**0**	X-Content-Type-Options auf nosniff gesetzt. Empfehlung:
Referrer-Policy	**+5**	Referrer-Policy auf no-referrer, same-origin, strict-origin oder strict-origin-when-cross-origin gesetzt. Empfehlung:
X-Frame-Options	**+5**	X-Frame-Options über die CSP-Direktive frame-ancestors umgesetzt. Empfehlung:
Cross-Origin-Opener-Policy	**+10**	Cross-Origin-Opener-Policy header set to same-origin, enforcing site isolation from the opener. Empfehlung:
Cross-Origin-Resource-Policy	**+10**	Cross Origin Resource Policy (CORP) implemented, prevents leaks into cross-origin contexts. Empfehlung:

B

Methodik und Bewertung

VORGEHEN

Alle Werte wurden am 30. Oktober 2026 automatisiert mit scan.reineke.tech erhoben, DNS-Abfragen über Cloudflare DNS-over-HTTPS (1.1.1.1). DKIM lässt sich nur über gängige Selektoren prüfen. Die Website-Bewertung nutzt den MDN HTTP Observatory von Mozilla und gilt nur für die Startseite, nicht für Portale oder Subdomains. Ausgewertet wurden nur öffentlich abrufbare Informationen, ohne Anmeldung, Eingriff oder nennenswerte Last. Die Ergebnisse sind eine Momentaufnahme; auf Anfrage prüfen wir kostenfrei erneut.

E-Mail DMARC, SPF, DKIM, MX, MTA-STS, TLS-RPT	DMARC legt fest, wie Mailserver mit E-Mails umgehen sollen, die Ihre Absenderadresse nur vortäuschen: „reject“ weist ab, „quarantine“ sortiert aus, „none“ beobachtet nur. SPF und DKIM liefern die Prüfgrundlage.
Domain DNSSEC	DNSSEC signiert die Adressauskünfte Ihrer Domain. Prüfende DNS-Server erkennen so Fälschungen, die E-Mails oder Besucher umleiten könnten.
Website MDN HTTP Observatory	Der HTTP Observatory von Mozilla prüft die Schutzregeln Ihrer Website, etwa CSP und HSTS. Die Note ergibt sich aus gewichteten Punktabzügen.

NOTENSKALA

A+ / A / A−	SEHR GUT	Geprüfter Schutz umgesetzt
B+ / B / B−	GUT	Geringfügige Verbesserungen möglich
C+ / C / C−	VERBESSERUNGSWÜRDIG	Bei nächster Gelegenheit angehen
D+ / D / D−	MANGELHAFT	Zeitnah beheben
F	UNGENÜGEND	Wesentlicher Schutz fehlt

Vertraulich – bestimmt für den Inhaber der geprüften Domain und dessen IT-Dienstleister.